

SHIELD: A Six-Layer AI-Enabled Cybersecurity Framework for ICS/OT Environments

By: Muhammad Ali Khan

OT/ ICS Cybersecurity Specialist

AAISM | CISSP | CISA | CISM | CEH | ISO27001 LI | CHFI | CGEIT | CDCP

Abstract

Industrial control systems (ICS) and Operational Technology (OT) are up against fast-evolving threats that are advancing faster than the security measures designed to protect them. Hackers are now using the same features that make industrial systems reliable, that is, predictable behaviour, legacy systems, and the need to stay running, avoiding being detected and staying hidden. Artificial Intelligence (AI) can detect and prioritise threats in OT environments efficiently. However, using AI effectively requires plans to be made and executed very carefully due to AI having unique challenges of its own. This article introduces the S.H.I.E.L.D Framework: A Six-layer cybersecurity model for OT/ICS that combines AI-based threat detection, robust protection, zero-trust principles, risk prediction, and industry-standards compliance.

The Emerging Challenge: Why ICS/OT Security Needs Rethinking

ICS/OT environments are facing rapidly evolving cyber threats that traditional security models cannot address effectively. These systems are designed for reliability and continuous operation, which rely on legacy technologies, predictable behaviour, and limited security controls—making them inherently vulnerable to modern, stealth-based attacks.

Today's adversaries exploit these characteristics to remain undetected, operating within normal system behaviour rather than triggering alarms. At the same time, the growing adoption of artificial intelligence (AI) in industrial environments introduces both opportunity and risk.

The need for AI-driven cyber defence has grown in the OT/ ICS space as recent threat escalations made the traditional approaches not nearly enough.¹ The attackers no longer exploit known vulnerabilities, rather they are learning and adapting the industrial operations. They exploit the weaknesses in legacy protocols and stay out of radar for an extended period. They operate within the normal system behaviour to avoid being detected.

This creates a clear need for a new approach— that aligns with deterministic nature of ICS/OT systems while integrating AI in a controlled and resilient manner.

S.H.I.E.L.D. Framework: Architecture and Rationale

The S.H.I.E.L.D Framework is designed to address the ICS/ OT Cybersecurity requirements in a structured approach through practitioner experience securing industrial systems across manufacturing, energy, transportation, utility and telecommunications critical infrastructure. This framework embeds AI-driven features in its overall approach to protect the OT/ ICS environments. The framework is not a product or a theory. It is a practical approach any organisation can use to improve security without replacing the existing systems.

S.H.I.E.L.D. is a containment strategy and a defence architecture designed for real-world operations. The aim is to create perfect conditions where an operational environment can be designed and function securely.

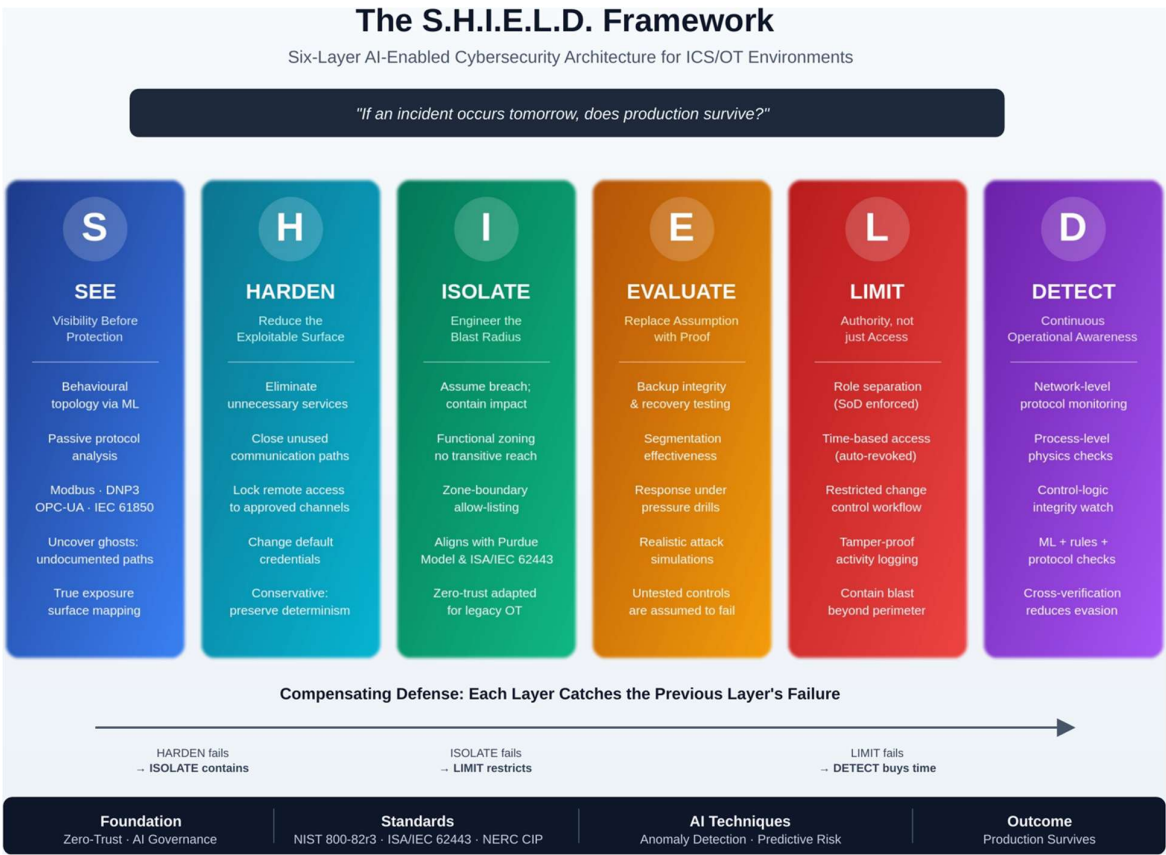


Figure 2 — The S.H.I.E.L.D.™ Framework: Six-Layer Containment Architecture. Each layer compensates for the failure of the previous one. The strength of S.H.I.E.L.D.™ lies not in any individual layer but in the ordering: when HARDEN fails, ISOLATE contains; when ISOLATE fails, LIMIT restricts; when LIMIT fails, DETECT buys time.

The framework has five layers, arranged in a specific order, each designed to recover from the layer before it. When HARDEN fails, ISOLATE limits the spread. If ISOLATE fails, LIMIT reduces the impact. If LIMIT fails, DETECT reduces the time to respond faster. This compensating structure is the reason why S.H.I.E.L.D. is different from the traditional compliance frameworks.

Hence, the governing question is not whether the organisation is compliant or whether it has the right tools. The governing question is: *if an incident occurs tomorrow, does production survive?*

S — SEE: Visibility Before Protection

The first principle of S.H.I.E.L.D is to see, and the framework's definition of this layer extends significantly beyond traditional asset inventory. See addresses the deeper operational realities, like what influences production, what is reachable from where and where the control authority actually resides within the network architecture.

Within this layer, AI machine learning is used to construct a behavioural topology rather than just relying on its design or documented state. Passive analysis of industrial protocols such as Modbus, DNP3, OPC-UA, and IEC 61850 traffic reveals undocumented connections, unsanctioned remote access paths, and control relationships that exist in firmware but not in network diagrams.²

H — HARDEN: Reducing the Exploitable Surface

Once the true exposure surface is established through SEE. HARDEN reduces it systematically. Within the OT/ICS environments, S.H.I.E.L.D. adopts a deliberately conservative hardening philosophy to eliminate unnecessary services, close the unused communication paths and lock remote access to explicitly authorised channels.

HARDEN specifically targets the discrepancies between the documented network and the actual Network, undocumented connections, unused remote access services left by vendors and default credentials that configuration standards require to be changed, but the asset inventories rarely verify have been changed.³

I — ISOLATE: Engineering the Blast Radius

Even in hardened environments, compromise and breach must be assumed. The assumption that hardening is sufficient is dangerous in industrial security. Advanced persistent threat actors targeting OT/ICS environments are patient, well-resourced, and capable of exploiting vectors that hardening does not address.

ISOLATE is designed around this reality and focuses on controlling the impact of failure, ensuring that compromise remains local. This is achieved through real-time functional zoning with no transitive reachability.

The ICS/ OT environment is required to be segregated by considering the different operational/ protection layers defined in Purdue Model and ISA/IEC 62443-3-3.⁴ This segregation is required to be fit into legacy OT environments while improving how networks are separated and protected.

SHIELD × Purdue Model: Zone Mapping & Security Levels			
Each Purdue zone mapped to SHIELD controls and ISA/IEC 62443-3-3 Security Levels			
Purdue Level	Zone / Assets	SHIELD Security Controls	ISA 62443 Security Level
L5 Enterprise Network	Business / ERP Systems Corporate email, ERP, CRM, internet-facing services Standard IT security domain	SEE · DETECT Standard IT controls; monitor ingress to DMZ Identity-based authentication (full zero-trust)	SL 1–2
L4 Business Planning	Site Business Systems Site-level MES reporting, production scheduling Interfaces enterprise ↔ operations	HARDEN · ISOLATE · DETECT Harden endpoints; restrict remote access DMZ gateway controls (CIP-005 aligned)	SL 2
⚡ IT/OT DMZ Phase 3 boundary — Data diodes / unidirectional gateways · Zero-trust enforcement · Primary SHIELD containment line			
L3 Site Operations	Historians · Engineering Workstations Data historian, batch mgmt, domain controllers Jump servers, patch mgmt, AV consoles Entry point for most OT compromises	SEE · HARDEN · ISOLATE · LIMIT · DETECT Full SHIELD stack · Allow-listed comms only Role separation; time-based privileged access ML baseline + rule-based protocol monitoring	SL 2–3
L2 Area Supervisory	HMIs · SCADA · Control Servers Operator HMIs, alarm servers, engineering tools Modbus, DNP3, OPC-UA, IEC 61850 traffic Where behavioural baselines are built	SEE · ISOLATE · LIMIT · DETECT Passive protocol analysis for topology Micro-segmentation between HMI ↔ controllers Change windows; MFA for admin sessions	SL 3
L1 Basic Control	PLCs · RTUs · DCS Controllers Deterministic cycle times (often 10–100 ms) No identity-based auth on legacy devices Hardening must not break control determinism	HARDEN · ISOLATE · DETECT (control-logic) Conservative hardening; verify under load Zone-boundary enforcement upstream Watch for unauthorized logic changes	SL 3
L0 Physical Process	Sensors · Actuators · Field Instruments Pressure, flow, temperature — physics itself Primary target for signal-manipulation attacks	DETECT (process-level physics checks) Cross-check sensor readings vs. expected physics Detect values within protocol but outside reality	SL 3–4
SAFETY SIS / SIL-rated	Safety Instrumented Systems Emergency shutdown, fire/gas, safety logic solvers	ISOLATE (air-gapped) · DETECT Dedicated network; no upstream transitive reach	SL 4
SL 1: casual violation · SL 2: intentional w/ low resources · SL 3: intentional w/ moderate resources · SL 4: intentional w/ extended resources Zero-trust enforced at zone boundaries — not on legacy field devices. SHIELD adapts ISA/IEC 62443 & NIST SP 800-82r3 to legacy OT constraints.			

Figure 3 — SHIELD Framework: Purdue Model Zone Mapping. The framework maps each Purdue Model zone to a specific set of SHIELD security controls, enabling zero-trust enforcement without requiring legacy OT devices to support identity-based authentication.

E — EVALUATE: Replacing Assumption with Proof

Anything that has not been tested should be assumed to fail. The Evaluate layer in the framework turns security into something proven in real operations. Instead of trusting documentation or assumptions, it requires real testing under realistic conditions. The AI model that constructed behavioural topology under SEE phase are utilized here to evaluate the deviance from actual vs malicious operational activities.

L — LIMIT: Authority, Not Just Access

Access levels can not determine the impact unless it is confirmed that how much control someone has. Limit actually focuses on this key idea; if an attacker gets access but can not make changes by not gaining access to admin rights, the situation can still be contained. The AI models are utilized to determine the footprint of any adversaries present in the environment trying to escalate the privileges and gain higher controls.

However, if an attacker has full control, it becomes a serious system-wide risk. The goal of LIMIT is to keep most security breaches in a “contained and manageable” state. An attacker with admin rights is a disaster⁸. LIMIT is about making sure that even when someone gets inside, they can't actually *do* anything. It is done using four main controls:

Role Separation: No single employee can do both, view and change critical systems.

Time-Based Access: Higher-level permissions are only given temporarily for specific tasks and are removed automatically afterwards.

Restricted Changes: Only preselected and approved accounts should be able to make the changes, and they should follow a proper process.

Activity Tracking: All important actions are logged in a secure way that can not be altered or hidden.

These controls follow established standards like NIST SP 800-82 and ISA/IEC 62443 for managing access and enforcing least privilege in industrial systems.^{6,7}

D — DETECT: Continuous Operational Awareness

Detect turns S.H.I.E.L.D from a fixed security framework into a system that is highly alert. None of the previous layers guarantees that an attack will not happen. DETECT makes sure that if anything does go wrong, it is immediately noticed and can be acted on.

There are 3 levels to this.

Network level: This level monitors the communication, such as Modbus, OPC-UA, etc., and checks for unusual patterns compared to normal behaviour.

Process level: This level looks at real-world data like pressure flow and system states to see if they match what should be happening; if anything does not add up, it is to be taken as a strong warning sign.

Control logic level: Here, the layer watches systems like PLCs and RTUs for unauthorised changes or unusual behaviour in how they run.

Detect also works closely with other layers. With LIMIT, it checks if suspicious activity involves using more authority than they should.

The importance of DETECT is in the speed. In OT/ICS systems, the longer an attack is unnoticed, the more likely the damage, so DETECT focuses on spotting problems early, even if it means more alerts at first, which are filtered and analysed. AI machine learning boosts this capability significantly in terms of speed and accuracy of threat detection in the delicate and complex nature of operational network traffic.

Implementation Sequence and Practical Guidance

The SHIELD Framework is meant to be applied step by step, not all at once. Most organisations operating legacy ICS/OT infrastructure cannot fully upgrade their security in a single project cycle, and in doing so, it produces operational disruption or ends up with security that looks good on paper. So instead, the framework recommends starting with visibility to understand what's actually happening in the infrastructure before adding strict controls. This principle is drawn from operational experiences across multiple critical infrastructures.

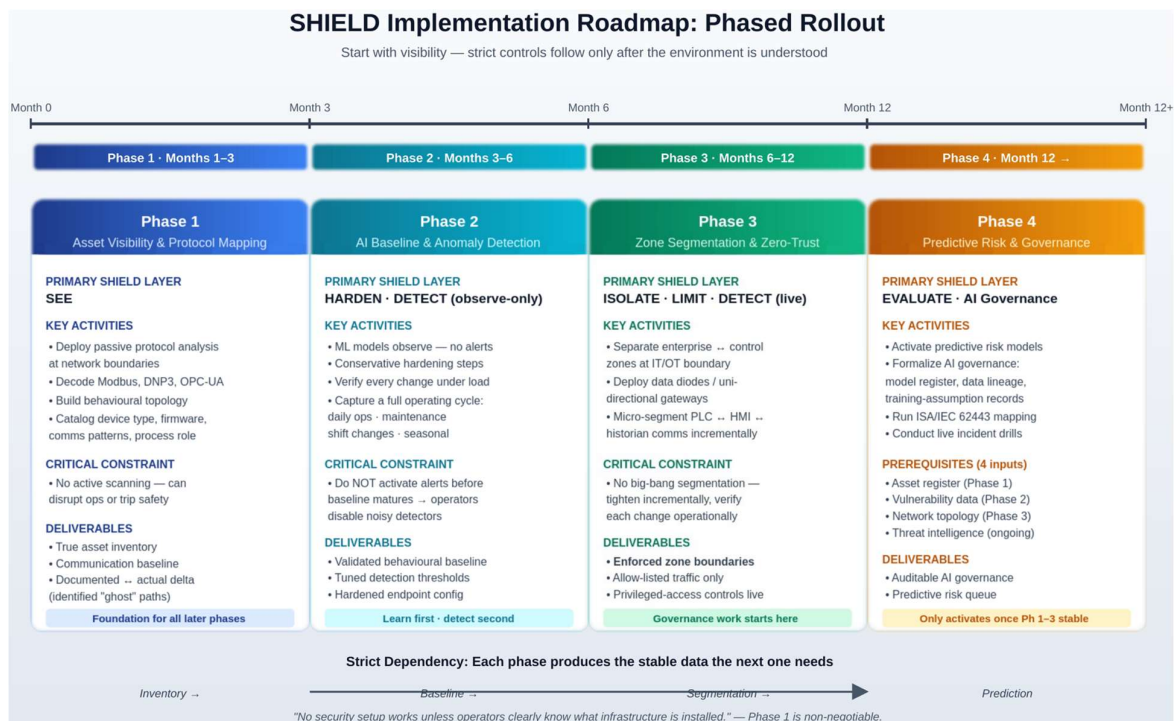


Figure 4 — SHIELD Implementation Roadmap: Phased Rollout

Phase 1: Asset Visibility and Protocol Mapping (Months 1–3)

No security setup effectively works unless operators clearly know what infrastructure and asset inventory is installed. In ICS/OT environments, this has to be done carefully as active network scanning can disrupt operations or trigger safety systems in certain environments.

Hence, instead of scanning, passive protocol analysis tools are deployed at network boundaries because these tools quietly observe network traffic, understand industrial protocols like Modbus, DNP3, and OPC-UA.

Using this, operators build a detailed list of assets that includes device type, firmware version, communication patterns, and process role. This information becomes the foundation for the rest of the framework, helping with visibility (SEE), system protection (HARDEN), and threat detection (DETECT).

Phase 2: AI Baseline Construction and Anomaly Detection Deployment (Months 3–6)

Behavioural baselining requires a defined learning period during which the detection model observes normal operation patterns while not raising alerts. In OT/ICS systems, the period expands at least one whole operation cycle that includes daily operational activity, the maintenance period, the shift changes and seasonal process variations. This is to ensure the system understands all normal behaviour.

Phase 3: Zone Segmentation and Zero-Trust Enforcement (Months 6–12)

In this phase, the focus is on separating and controlling the enterprise zone and the control zone, as this boundary is where the spread of compromise from IT systems into OT systems is most commonly observed.

Within individual zones, micro segmentation of communication paths between controllers, HMI's and historians can then be introduced incrementally. This approach avoids the need for simultaneous large-scale changes across the entire OT environment while progressively tightening internal communication boundaries.

Phase 4: Predictive Risk Integration and Governance Documentation (Month 12 onward)

Predictive risk modelling only becomes useful once the earlier layers are producing stable and reliable data. It depends on four key inputs: an asset register, vulnerability data, network topology, and threat intelligence. None of these is available unless phases 1 to 3 are completed.

Selected performance outcomes

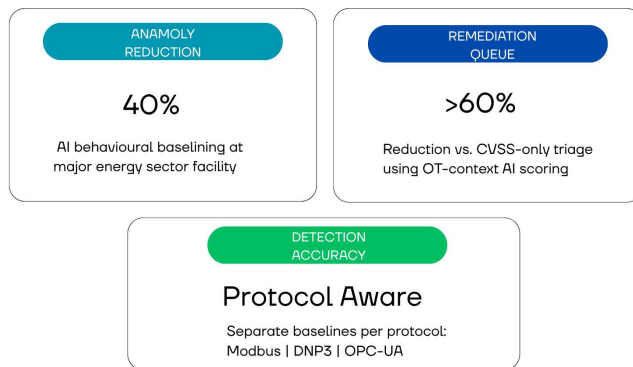


Figure 4 — Selected performance outcomes from SHIELD Framework deployments. Anomaly reduction data documented by an independent third-party observer engaged by the client organisation. Remediation queue data from multi-facility deployment across the U.S. manufacturing infrastructure

Adversarial AI: Securing the Framework Itself

A security framework that deploys AI without addressing the AI's security creates a new attack surface. Adversarial AI is when attackers manipulate or trick machine learning systems by altering data, inputs, or signals so that malicious activity appears normal and goes undetected. In industrial systems are especially dangerous because failures can lead to real-world damage.⁹ There are three main ways attackers can target AI within the S.H.I.E.L.D. Framework:

Data poisoning: Data poisoning targets training datasets or live telemetry, slowly shifting the model's baseline so that malicious activity is learned as normal behaviour.

Model evasion: Model evasion exploits the model's decision boundary by crafting inputs that appear legitimate within ICS/OT systems. This often involves protocol traffic that mimics normal operations while embedding malicious commands.

Signal manipulation: Industrial signal manipulation operates at the physical layer, altering PLC commands or sensor outputs to remain within expected protocol patterns while causing real-world process deviations.

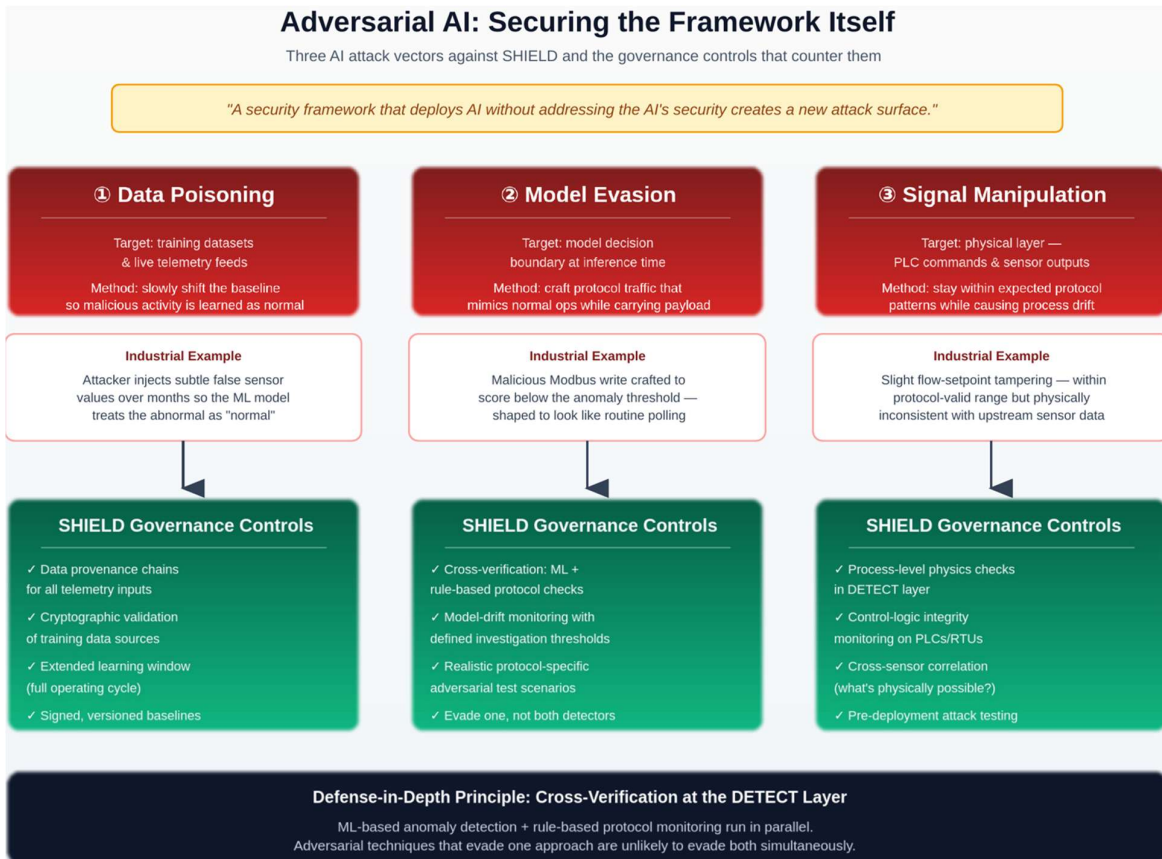


Figure 5 — Adversarial AI: Securing the Framework Itself

To address these risks, the S.H.I.E.L.D. framework incorporates specific governance and validation controls. These include establishing data provenance chains for all telemetry inputs, applying cryptographic validation to training data sources, and implementing model drift monitoring with defined investigation thresholds for statistical deviations. Additionally, the system must be tested using realistic, protocol-specific attack scenarios before any AI model is put into real-world use.

Standards Alignment and Regulatory Considerations

The S.H.I.E.L.D. Framework's Layer 4 governance requirements are beyond a compliance checklist. It establishes a direct alignment between the framework's technical controls and the regulatory and standards landscape governing U.S. critical infrastructure.

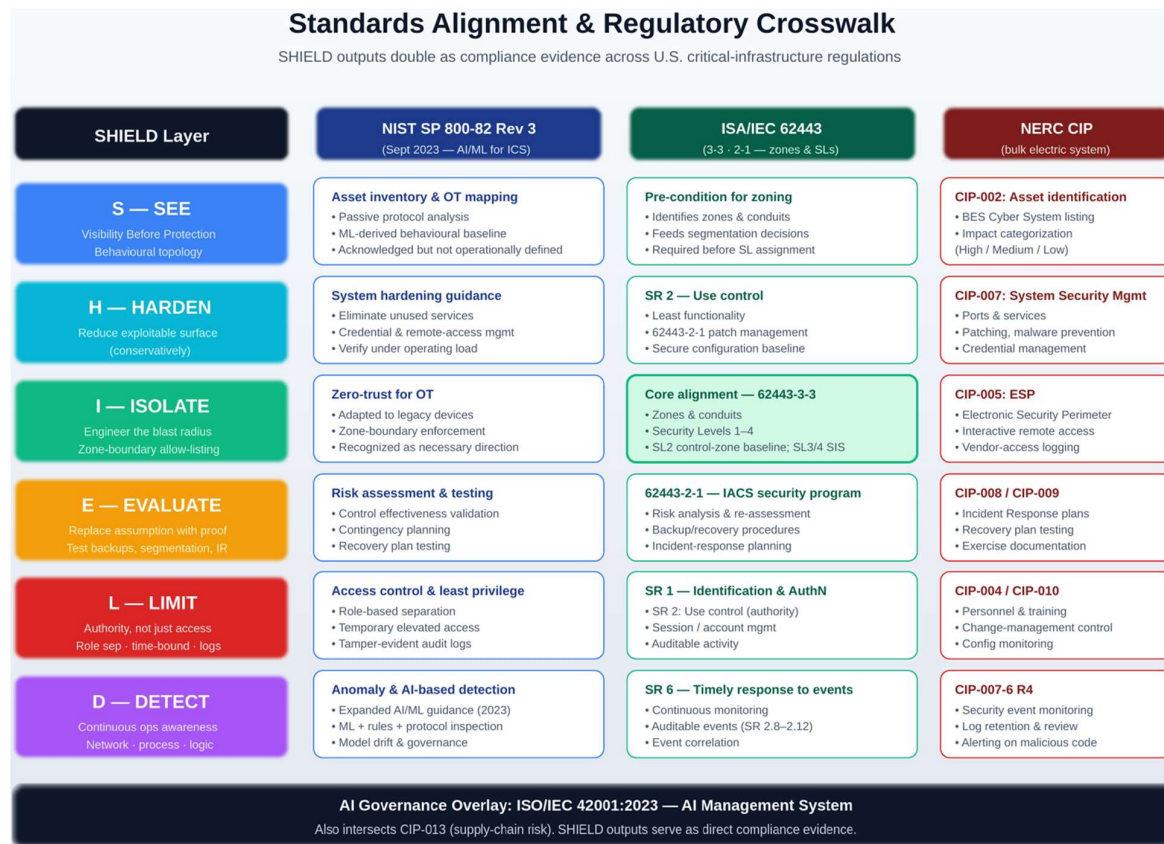


Figure 6 — Standards Alignment & Regulatory Crosswalk

NIST SP 800-82 Revision 3, published in September 2023, expands guidance on AI and machine learning in ICS environments and introduces updated direction on zero-trust principles for OT networks.⁶ The S.H.I.E.L.D Layer 2 implementation reflects this guidance, adapting zero-trust concepts to the constraints of OT systems in a way that the standard acknowledges as necessary but does not operationally define.

ISA/IEC 62443-3-3 provides the security level classification model that informs zone segmentation decisions within Layer 2¹⁰. Security Level 2 protection against intentional violations using low resources is generally the minimum baseline for control zone assets, while process safety systems may require Security Level 3 or 4. The S.H.I.E.L.D. Framework maps Purdue Model zones to these security levels, creating a direct link between implementation and compliance documentation.

The North American Electric Reliability Corporation Critical Infrastructure Protection (CIP) standards introduce specific regulatory requirements for bulk electric system operators. These intersect with multiple S.H.I.E.L.D controls, particularly in areas such as electronic security perimeters (CIP-005), system security management (CIP-007), and supply chain risk

management (CIP-013).¹² Organisations operating under NERC CIP can leverage S.H.I.E.L.D. outputs directly as supporting artefacts for compliance evidence.

Conclusion

The S.H.I.E.L.D. Framework represents a practitioner-driven integration of security capabilities that have traditionally been developed in isolation within the ICS/OT security domain, AI-based detection, zero-trust architecture, predictive risk modelling, and standards-aligned governance. Its value does not lie in the novelty of any single component, but in its structured integration into a deployable architecture that accounts for the operational constraints of industrial environments.

The framework addresses a fundamental barrier to the adoption of advanced security controls in ICS/OT: the inherent tension between security and operational continuity. By building from the operational layer upward, adapting to the deterministic nature of industrial systems, and enabling phased implementation that delivers measurable protection at each stage, S.H.I.E.L.D. provides a practical path to security maturity without disrupting production.

Threat intelligence from organisations such as the Cybersecurity and Infrastructure Security Agency and the FBI Internet Crime Complaint Centre, along with independent industrial security research, confirms that both state-sponsored and criminal actors are actively targeting critical infrastructure environments.¹³ The Volt Typhoon campaign, characterised by long-term, low-visibility persistence within U.S. infrastructure, demonstrates the limitations of signature-based and perimeter-focused security models in OT contexts.

Endnotes

1) Khan, Muhammad Ali; "The New Battleground for ICS/OT: Why AI-Driven Defence Is Becoming Essential for ICS/OT Cybersecurity"; ISACA; 6 April 2026; isaca.org

2) Dragos Inc.; "ICS/OT Cybersecurity Year in Review 2024"; Dragos; 2025; dragos.com/resources/industrial-control-systems-ics-ot-cybersecurity-year-in-review/

3) Stouffer, Keith; Lightman, Suzanne; et al.; NIST Special Publication 800-82 Revision 3: Guide to OT Security; National Institute of Standards and Technology; September 2023; doi.org/10.6028/NIST.SP.800-82r3

4) International Society of Automation; "ANSI/ISA-62443-3-3 (99.03.03)-2013: Security for Industrial Automation and Control Systems: System Security Requirements and Security Levels"; ISA; 2013; isa.org

5) Lee, Robert M.; Miller, Tim; "SANS ICS Security Survey 2024"; SANS Institute; 2024; sans.org/white-papers/

6) Stouffer et al., NIST SP 800-82 Revision 3; op. Cit

7) International Society of Automation; "ANSI/ISA-62443-2-1 (99.02.01)-2009: Security for Industrial Automation and Control Systems: Establishing an IACS Security Program"; ISA; 2009; isa.org

- 8) MITRE Corporation; "MITRE ATT&CK; for ICS"; MITRE; 2025; attack.mitre.org/matrices/ics/
- 9) Modbus Organization; "Modbus Application Protocol Specification V1.1b3"; modbus.org; 2012; modbus.org/docs/Modbus_Application_Protocol_V1_1b3.pdf
- 10) Stouffer et al., NIST SP 800-82 Revision 3; op. cit.
- 11) International Organization for Standardization; "ISO/IEC 42001:2023 Artificial Intelligence — Management System"; ISO; December 2023; iso.org/standard/81230.html
- 12) North American Electric Reliability Corporation; "NERC CIP Standards"; NERC; 2024; nerc.com/pa/Stand/Pages/CIPStandards.aspx
- 13) Cybersecurity and Infrastructure Security Agency; "CISA ICS-CERT Advisories and Emergency Directives 2025–2026"; CISA; cisa.gov/ics-cert/advisories

ABOUT THE AUTHOR

Muhammad Ali Khan (MSc, AAISM, CISSP, CISM, CISA, CGEIT, CEH, CHFI, ISO/IEC 27001 Lead Implementer) is an AI-driven ICS/ OT Cybersecurity Specialist with 17 years of experience securing critical infrastructure across manufacturing, energy, utility, telecommunications, and transportation sectors. Muhammad currently leads AI-driven OT vulnerability management across 19 U.S. industrial manufacturing facilities for a manufacturing client.

Professional publications are available at:

icsotsec.ai - linkedin.com/in/malikhan-ai-ics-ot-cybersecurity - itsec.alikhan@gmail.com